



Password & Account Security Policy

BluePeak Technologies | Identity, authentication, and account protection

Document ID	BPT-IT-IAM-126	Version	v1.0
Effective date	2026-08-01	Next review	2027-02-01
Owner	Identity and Access Management	Approved by	Executive Leadership Team
Classification	Internal	Category	IT and Security
Audience	All employees	Status	Approved
Source	https://employee.bluepeaktech.com/resources/it-security/policies/password-account-security	Access scope	All employees

Document purpose. BluePeak passwords, passphrases, passkeys, MFA, password managers, account sharing, recovery, privileged and service accounts, guest access, sign-in protection, and account lifecycle.

Contents

Quick Answers 3

1. Purpose and Scope 3

2. Identity Principles 3

3. Password and Passphrase Standard 3

 3.1 Minimum Requirements 3

 3.2 Rotation 4

4. Password Manager 4

5. Multi-Factor Authentication 4

 5.1 MFA Prompt Safety 5

6. Account Use and Sharing 5

7. Sign-In and Session Security 5

8. Account Recovery and Help Desk Verification 5

9. Privileged Accounts 5

10. Service Accounts, Secrets, and API Credentials 6

11. Guest, Vendor, and Customer Access 6

12. Account Lifecycle 6

 12.1 Joiner 6

 12.2 Mover 6

 12.3 Leaver 6

 12.4 Inactivity 6

13. Emergency Access 6

14. Reporting and Response 6

15. Exceptions and Enforcement 7

90. Administration, Exceptions, and Questions 7

91. Related Documents and Systems 7

Revision History 7

Quick Answers

Question	Current rule
What is the minimum password length?	14 characters for a standard user account and 16 for an account that permits privileged administration, unless the system enforces a stronger standard.
Must passwords contain a symbol and number?	No fixed composition pattern is required when the 14-character minimum and blocked-password screening apply. A long, unique passphrase is preferred.
How often must I change my password?	Not on a fixed schedule. Change it when compromise is suspected or confirmed, the system directs it, or account risk changes.
May I reuse a personal password?	No. Every BluePeak password must be unique to the BluePeak account.
Where should passwords be stored?	In BluePeak's approved enterprise password manager; never in a document, browser outside the managed profile, chat, or paper left unsecured.
Is MFA required?	Yes, for Entra ID and every supported company or customer system. Phishing-resistant methods are preferred.
May I approve an MFA prompt I did not initiate?	No. Deny it and report it immediately.
May a team share one login?	No, unless Identity and Security approve a technical exception with named accountability.

Security will never ask for your password or MFA code. A request for a one-time code, passkey approval, password-manager export, or recovery token is a security incident.

1. Purpose and Scope

This policy protects BluePeak identities and accounts from unauthorized access. It applies to employees, contractors, guests, administrators, developers, service owners, and any person using a BluePeak-issued or BluePeak-managed account.

It covers Microsoft Entra ID, SaaS applications, source repositories, cloud platforms, customer environments, devices, service accounts, API credentials, privileged identities, and emergency access. A customer or regulated system may require stronger controls.

2. Identity Principles

- 1 One human, one uniquely attributable primary account.
- 1 Strong MFA for every supported service.
- 1 Passwordless or phishing-resistant authentication where available.
- 1 Least privilege and separate privileged accounts.
- 1 No credential sharing or approval of another person's sign-in.
- 1 Verified recovery and prompt removal of stale access.
- 1 Credentials stored only in approved systems and never in source code.

3. Password and Passphrase Standard

3.1 Minimum Requirements

A password for a standard account must be at least 14 characters. A password for an account capable of privileged administration must be at least 16 characters, unless the platform uses an approved passwordless control or enforces a stronger rule.

Passwords must be unique and must not be:

- 1 used for any personal, customer, or other work account;
- 1 a known compromised or commonly guessed password;
- 1 based on the employee's name, username, company name, product, team, season, address, or readily available fact;
- 1 a predictable variation of a prior password; or
- 1 a repeated character, keyboard walk, or simple substitution.

A long passphrase made from unrelated words is preferred. Fixed complexity recipes such as one uppercase letter, one number, and one symbol are not a substitute for length and uniqueness.

3.2 Rotation

BluePeak does not require routine periodic password changes for a normally operating account. Forced frequent rotation can encourage predictable patterns. A password must be changed when:

- 1 compromise is suspected or confirmed;
- 1 a phishing or credential exposure event occurred;
- 1 Security or automated risk detection requires it;
- 1 an account was shared or handled improperly;
- 1 a vendor or system breach affects the credential;
- 1 a privileged or emergency credential reaches its approved expiration; or
- 1 the platform requires rotation for a technical or contractual reason.

Changing a password does not resolve malware or session theft by itself; contact Security so sessions, tokens, devices, and related accounts can be reviewed.

4. Password Manager

Users must store non-SSO passwords in the approved enterprise password manager. The manager generates unique passwords, controls team vaults, records access, and supports secure sharing without revealing credentials.

Do not store company credentials in personal password managers, ordinary browser sync, notes, spreadsheets, tickets, email, Teams, source code, configuration files, or screenshots. The password manager's master credential and recovery material must be protected with MFA and must not be shared.

A team credential requires an approved shared vault with named members, owner, purpose, review date, and rotation. Copying it into chat to make access easier is prohibited.

5. Multi-Factor Authentication

MFA is required for Entra ID and all supported company and customer systems. Approved methods, from strongest to fallback, are:

- 1 FIDO2 security key or device-bound passkey;
- 2 Windows Hello for Business or approved platform credential;
- 3 Microsoft Authenticator number matching or another approved push method;
- 4 time-based one-time password in the approved authenticator; and
- 5 SMS or voice only as an approved temporary fallback.

Users should register at least two approved methods where possible, such as a passkey and backup security key. Personal email is not an approved recovery factor for a workforce account.

5.1 MFA Prompt Safety

Approve a prompt only when the user initiated the sign-in and the displayed number, application, and location are expected. Repeated or unexpected prompts are often an attack. Deny the prompt, change the password only when directed, and report it immediately.

No help-desk agent, manager, executive, customer, or law-enforcement contact will ask the user to read or approve an MFA code.

6. Account Use and Sharing

Users may access only their assigned accounts and may not let another person use a session, badge, security key, or device profile. Do not remain signed in on a shared conference-room or customer device.

A shared mailbox, queue, service principal, or application identity is not a shared human login. It must have an owner, approved access group, logging, and lifecycle. Generic human accounts require a documented exception.

Delegation should use the application's authorized delegation feature. An assistant, colleague, vendor, or IT support person should never need the employee's password.

7. Sign-In and Session Security

Lock the screen whenever leaving a device unattended. Sign out of public, borrowed, or customer systems. Do not select "stay signed in" on an unmanaged device. Browser sessions, refresh tokens, app passwords, and cookies are credentials and must be protected.

Conditional access may restrict sign-in based on device health, location, network, user risk, application, or data sensitivity. Attempts to bypass these controls through VPN masking, token copying, unapproved remote desktop, or personal devices are prohibited.

Report an unexpected sign-in alert, unfamiliar device, impossible travel notice, missing session, or application consent request to Security.

8. Account Recovery and Help Desk Verification

Use the approved self-service password reset process. When help-desk assistance is needed, the Service Desk verifies identity using approved factors and may require a video check, manager confirmation, registered device, or Security review. Publicly available facts, caller ID, and email alone are not sufficient for a high-risk reset.

The Service Desk will not ask for an existing password, MFA code, full recovery seed, or password-manager export. A reset performed during suspected compromise must include session revocation and device review.

A user who loses all authentication methods should contact servicedesk@bluepeaktech.com through a verified channel. Security may place a temporary access hold while identity is confirmed.

9. Privileged Accounts

Administrative access uses a separate named privileged account and is not used for routine email, web browsing, chat, or document editing. Privileged activation should be just-in-time, time-limited, MFA-protected, approved when required, and logged.

Administrators must use an approved managed workstation and may not export credentials or tokens. High-impact actions such as changing authentication policy, granting global roles, accessing restricted HR data, modifying payment controls, or changing AI document permissions may require two-person approval.

Privileged access is reviewed at least quarterly and removed promptly when no longer needed.

10. Service Accounts, Secrets, and API Credentials

Non-human identities require a named business owner and technical owner, documented purpose, minimum permissions, approved authentication method, environment separation, monitoring, and expiration or review date.

Use managed identities, workload identity federation, certificates, or short-lived tokens instead of static secrets where supported. Store secrets in the approved vault. Never put a secret in source code, a container image, CI/CD variable visible to broad users, ticket, log, wiki, email, or AI prompt.

A discovered secret is treated as compromised: revoke or rotate it immediately and review use. Simply deleting it from the latest source commit is not sufficient because history and logs may retain it.

11. Guest, Vendor, and Customer Access

Guest access must be sponsored by a BluePeak owner, limited to the required resource, protected by MFA, and given an expiration or review date. A sponsor reviews access at least quarterly for sensitive systems. Guest access should use the guest's organizational identity rather than a generic account.

Vendor support access is enabled only for the approved period and monitored according to risk. Remote-control sessions require user awareness or an approved unattended-support process.

12. Account Lifecycle

12.1 Joiner

Accounts are created from an approved identity record and role-based request. Access begins no earlier than needed, with sensitive or privileged access separately approved.

12.2 Mover

A manager or system owner reviews access when role, department, manager, customer assignment, location, or employment status changes. Old access is removed rather than merely adding new access.

12.3 Leaver

Interactive access is disabled no later than the authorized separation time and earlier when Security or People Operations directs. Sessions, tokens, keys, badges, remote access, and delegated permissions are revoked. Business files and mailbox ownership are transferred through an approved process; a manager may not continue using the former employee's credentials.

12.4 Inactivity

Dormant accounts are disabled according to risk and platform capability. Guest, service, shared, and emergency accounts receive scheduled review. Re-enablement requires identity verification and owner approval.

13. Emergency Access

Emergency or “break glass” accounts exist only for recovery from identity-platform failure. They are tightly limited, independently monitored, protected by strong offline controls, and tested on a defined schedule. Use triggers immediate Security review and credential rotation.

Employees must not create personal backdoor accounts or permanent access “just in case.”

14. Reporting and Response

Report phishing, an exposed credential, unexpected MFA prompt, suspicious sign-in, missing security key, unauthorized access, or accidental sharing to security@bluepeaktech.com immediately. Do not continue signing in repeatedly, negotiate with an attacker, or conceal the event.

Security may revoke sessions, disable accounts, isolate devices, reset factors, rotate secrets, review logs, and notify affected owners. Good-faith reporting is protected from retaliation.

15. Exceptions and Enforcement

An exception requires Identity and Security approval, a business justification, affected systems, compensating controls, owner, and expiration date. Legacy-system limitations must have a remediation plan.

Credential sharing, bypassing MFA, approving fraudulent prompts, unauthorized account creation, or concealment of compromise may result in access suspension and corrective action up to termination.

90. Administration, Exceptions, and Questions

BluePeak administers password and account security consistently with the employee's work location, employment classification, written employment terms, and applicable law. A statutory or contractual entitlement that is more generous than this document will apply to the extent required. A manager may not waive a legal requirement, create a new benefit, or promise an exception without written approval from the document owner.

Employees should raise questions before relying on an informal interpretation. Contact servicedesk@bluepeaktech.com through Outlook or the People Help channel in Microsoft Teams. Payroll, Legal, Information Security, or a site leader will be consulted when the question involves tax, wage-and-hour, privacy, immigration, safety, or local-law considerations.

Approved exceptions must identify the employee, the policy provision, the business reason, the approving authority, the start and end date, and any conditions. Exceptions are stored with the employee or transaction record and do not establish a precedent for other employees.

91. Related Documents and Systems

Resource	When to use it
Information Security Policy	Classification, access control, incident response, and security governance.
Acceptable Use of Company Devices	Device sessions, software, monitoring, and endpoint responsibilities.
Remote Work Policy	Approved locations and remote-access requirements.
New Hire Guide	Initial Entra ID, MFA, password manager, and device setup.

Revision History

Version	Effective date	Change summary
v1.0	2026-08-01	Established passwordless-first authentication, minimum passphrase requirements, MFA methods, and account lifecycle controls.